

CONTROLPLANE.AI

Evidence before answer

Detailed business proposal

PROOF-FIRST

Every high-impact claim must earn the right to be spoken.

MODEL-AGNOSTIC

Input/output enforcement works without model internals.

AUDIT-READY

Every decision ships with a complete, integrity-hashed receipt.

Team NewGenLabs

Track 1 / Submission-ready prototype / August 2026

SECTION 01

1. Executive Summary

Enterprises are deploying generative AI across customer chatbots, employee copilots, and decision-support tools at the same time as they consume foundation models through vendor APIs they do not own or control. In regulated domains such as banking and insurance, a single fluent-but-wrong answer - a misquoted foreclosure fee, a fabricated waiver promise, a leaked phone number - can cost more than the entire AI programme saved. Model confidence is not proof, and no enterprise can inspect model internals it does not own.

ControlPlane.ai is an evidence-enforcement middleware that sits at the input/output layer: evidence before answer; no proof, no confident claim. Every request is risk-routed before generation. High-stakes requests must satisfy a policy-authored fact contract - a checklist of facts, sources, and freshness SLAs that must be verified before any claim may be spoken. Claims use database lookups, calculations, rules, and a local similarity scorer for unstructured offer matching. The prototype makes no external LLM calls and reports zero model calls, tokens, and model cost. A decision gate issues tiered outcomes - ALLOW, EDIT, BLOCK, ABSTAIN, ESCALATE, HUMAN_CONFIRM, REDACT - and every answer ships with an integrity-hashed Evidence Receipt that makes each decision traceable for auditors and regulators.

A working prototype on a simulated retail-bank domain demonstrates all seven stages end-to-end with zero external calls: low-risk traffic clears in ~20 ms, contract-violating requests are blocked with clause citations, missing evidence produces honest abstention rather than guesses, conflicting sources escalate to humans, and PII disclosures are redacted with jurisdiction-cited law. The business case rests on three levers: avoided mis-selling and compliance penalties, reduced human review load through risk-tiered gating, and materially faster audit investigations backed by machine-readable evidence.

SECTION 02

2. Problem Framing - Confidence Is Not Proof

The asymmetry that breaks current deployments. A language model's fluency is uncorrelated with its factual correctness, yet enterprises are asked to treat both identically at the point of send. For a branch-hours question, a wrong answer costs seconds of customer time. For a foreclosure-fee question, the same class of error is mis-selling - a regulatory breach with financial penalties, remediation costs, and reputational damage. The cost of a wrong answer is asymmetric by use case, but today's guardrails treat every output with the same shallow confidence score.

Why post-hoc filtering is insufficient. The Round-2 brief identifies the real-world complexities precisely, and each defeats naive output filtering:

Brief complexity	Why post-hoc filtering fails
Overlapping risks (a fabricated detail about a person is simultaneously hallucination and privacy leak)	Single-purpose detectors fire independently, disagree, and cannot compose into one defensible verdict
No real-time ground truth	A filter that cannot verify a claim can only guess whether to trust it - reproducing the hallucination problem one level up
Over-flagging -> alert fatigue; under-flagging -> liability	Binary flag/no-flag output forces one trade-off for all traffic; the tuning problem is unsolvable without risk-tiering
Multi-turn conversations and acting agents compound risk	Filtering turn N in isolation misses how one questionable output shapes decisions in turns N+1...N+k
Regulation varies by geography and evolves	Hard-coded rules age quickly; policy must be configuration owned by compliance teams, not engineering
API-consumed foundation models	No access to internals, logits, or retrieval state - enforcement must work at the input/output layer

The conclusion we designed from: you cannot reliably classify bad answers after generation. You must change what generation is allowed to assert. That requires proof gathered before an answer is spoken - which is an architecture problem, not a model problem.

SECTION 03

3. Solution Design - The Seven-Stage Architecture

ControlPlane.ai is an inline middleware pipeline. The prototype implements it fully in deterministic Python on simulated bank systems-of-record (loan DB, contracts store, policy repo, CRM, offers engine, knowledge base); any resolver can be swapped for a live API without changing the logic.

```
Request --> 1 Risk Router --> 2 Fact Contract --> 3 Evidence Orchestrator
--> 4 Typed Claim Verifiers --> 5 Decision Gate --> 6 Wording Guard
--> Answer + 7 Evidence Receipt
```

1. Risk Router (pre-generation). Classifies every request before any text is produced: intent, LOW/MEDIUM/HIGH risk level, numeric score, confidence, and human-readable reasons. This is what makes latency affordable - only high-risk intents pay gate cost. 2. Fact Contract. Per-intent checklists of required facts: which system owns each fact ([LOAN_DB](#), [CONTRACTS](#), [POLICY](#), [CRM](#), [OFFERS](#), [KB](#)), its freshness SLA (e.g., loan status $\leq$ 1 day, fee policy $\leq$ 90 days), and whether it is critical (missing critical fact $\Rightarrow$ ABSTAIN). Contracts encode "what must be true before anything may be claimed." 3. Evidence Orchestrator. Retrieves permitted data from systems-of-record into a Verified Fact State where every fact carries value, source reference, version, age-vs-SLA, and a status of OK / STALE / MISSING / CONFLICTING. Cross-source conflict detection is built in (e.g., a CRM note promising an "automatic waiver" contradicted by current policy never auto-resolves). 4. Typed Claim Verifiers. Answers are decomposed into atomic claims, each routed to the appropriate local verifier: database lookup, calculator, rules engine, or similarity scorer. Independent claims run concurrently. Each verdict carries confidence, severity (hard = BLOCK path; soft = EDIT path), and evidence references. 5. Decision Gate. Deterministic precedence over verified state: CONFLICTING $\rightarrow$ ESCALATE; STALE $\rightarrow$ ESCALATE (refresh requested); MISSING/INSUFFICIENT $\rightarrow$ ABSTAIN; hard-contradicted feasibility $\rightarrow$ BLOCK with clause citation; soft-contradicted assumption $\rightarrow$ EDIT (corrected before send); all-proven $\rightarrow$ ALLOW. Under uncertainty the ladder only moves upward in caution, and a profile-level strictness threshold demotes ALLOW $\rightarrow$ EDIT $\rightarrow$ ESCALATE when aggregate evidence confidence falls below appetite. 6. Wording Guard. Final pre-send pass that rewrites biased or unsafe phrasing even when the underlying facts were proven, logging every substitution. 7. Evidence Receipt. Every decision emits a complete JSON receipt - routing reasons, fact contract, per-fact provenance and version, per-claim verifier/confidence/evidence, final answer, decision rationale, and performance block. The app seals it with a full SHA-256 hash, verifies the hash before writing, and appends the complete receipt to a JSONL audit log. Under the EU overlay, the receipt stores a query hash instead of plaintext.

Tiered decisions. ALLOW / EDIT / BLOCK / ABSTAIN / ESCALATE / HUMAN_CONFIRM / REDACT cover the full governance spectrum the brief asks for, including dual-control for irreversible actions ("transfer INR 50,000 from chat" $\rightarrow$ HUMAN_CONFIRM) and law-cited PII redaction.

Use-case profiles and jurisdiction overlays. Three profiles bind risk tolerance to latency budget: [customer_chatbot](#) (800 ms, strictness 0.35), [internal_assistant](#) (2,000 ms, 0.60), [decision_desk](#) (5,000 ms, 0.85). Geography overlays are pure configuration: India (DPDP Act 2023 + RBI Fair Practices Code, 365-day receipt retention), EU (GDPR + EU AI Act, minimised receipts, 90 days), US (GLBA + SR 11-7, 7-year archive).

Verifier economics - stated honestly. The prototype uses only local checks. Balance-transfer matching uses a weighted similarity scorer over governed borrower fields and unstructured offer text; it is not labelled as an LLM.

Similarity-proven claims carry capped confidence (0.78 vs 0.97 for deterministic facts), feeding stricter gate behaviour. Every receipt reports similarity-check count, external LLM calls, tokens, and estimated LLM cost. The last three remain zero in the current build.

Recent hardening. Since Round 1 the design has been hardened in seven ways: (i) fail-safe routing - unmatched requests fall to a conservative generic intent whose fast path abstains when no verified KB entry exists; (ii) measured latency reporting - receipts record actual timings and budget utilisation; (iii) the fact-contract registry is a versioned

YAML registry loaded fail-closed; (iv) independent claim verifiers run in parallel; (v) the live app carries multi-turn context, prior decisions, and loan identifiers into the next turn; (vi) GDPR minimisation removes plaintext queries from EU receipts and disk logs; and (vii) signed-contract authority means a generic policy can never shorten a customer-specific lock-in. The regression suite includes an 8-month-old loan with a signed 12-month lock-in and requires a BLOCK decision with the contract citation.

Feedback loop. Reviewer outcomes persist a separate gate-threshold offset for each intent. Approving an escalation moves that intent by -0.02; upholding it moves the intent by +0.02. The calibration survives restarts and does not alter unrelated intents. Batch audit reports risky-case recall, false-alarm rate on known-safe traffic, abstentions, p50/p95 latency, similarity checks, and zero external-LLM use.

SECTION 04

4. Target Users & Deployment

Who buys. Banking and insurance enterprises consuming foundation models via vendor APIs (OpenAI-class providers, or models served through cloud marketplaces) - exactly the consumption pattern the brief highlights, and the reason ControlPlane works purely at the input/output layer with no dependency on model internals.

Personas.

Persona	Pain today	What ControlPlane gives them
Chief Risk Officer	Unquantified liability from AI answers; no defensible control narrative	Tiered, tunable gating with fail-safe defaults; per-use-case strictness as board-reportable policy
Compliance / Audit & Model Risk	Cannot reconstruct why the AI said what it said	Integrity-hashed Evidence Receipts per decision; jurisdiction-tagged retention; replayable proof trail
CX / Digital leadership	Fear of blocking helpful automation; alert fatigue	Low-risk traffic stays fast (~20 ms); corrections instead of refusals where possible; measured over-flagging rates visible in batch audit

Where it sits. Inline middleware at the input/output boundary of each AI use case: request enters ControlPlane, is risk-routed, gated where warranted, then forwarded to the model with an evidence-constrained prompt; the draft passes the wording guard and ships with its receipt. Deployment is a sidecar/gateway alongside existing chatbot and copilot stacks - no model retraining, no vendor lock-in, no change to end-user surfaces.

SECTION 05

5. Business Case & Impact

Stated assumptions (per brief, illustrative): one mid-size bank running three AI use cases - customer support assistant, internal knowledge assistant, decision-support desk - with ~30,000 interactions/week combined; mix estimated at 70% low-risk, 25% medium, 5% high-risk based on prototype routing behaviour. All figures below are illustrative modelling, not measured client data.

Lever	Mechanism	Illustrative annual impact
Avoided mis-selling / compliance events	BLOCK/EDIT intercept wrong-cost and false-promise answers before send; receipts make remediation provable	If gating prevents even 2-3 material mis-selling events/year against an assumed INR 1-5 crore average cost per event (penalty + remediation), avoided loss is INR 2-15 crore
Reduced human review load	Only MEDIUM/HIGH traffic escalates; deterministic proofs clear the rest automatically	~30% of volume (~9,000/wk) hits the gate; assuming manual review would cost INR 80-150 per item, automation saves ~INR 4-7 crore/yr versus full-manual-review baseline
Faster audit investigation	Structured receipts replace hours of log archaeology per incident	If each audited interaction takes 3 h manually vs 20 min with a receipt, and audit samples 2,000 interactions/yr, ~INR 0.4-0.6 crore/yr of analyst time recovered
Latency economics	Low-risk traffic uses one governed KB lookup; independent high-risk checks run concurrently	Current prototype model spend is \$0 because it makes no external LLM calls; a future judge adapter would require separate measured economics before deployment

The core argument to a skeptical buyer: ControlPlane converts an unbounded tail-risk exposure (wrong answers at scale) into a fixed, measurable operating cost (gating infrastructure plus a small escalation workload), while producing the audit artefacts regulators increasingly demand anyway. The prototype's batch-audit panel reports caught-risk rate, false-alarm rate on safe traffic, abstentions, p50/p95 latency, local similarity-check count, external LLM calls, tokens, and estimated model cost.

SECTION 06

6. Phased Roadmap

Phase 1 - Working prototype (complete). Full seven-stage pipeline on a simulated retail-bank domain: eleven demo scenarios covering all seven decision tiers, three use-case profiles, three jurisdiction overlays, strictness slider with live batch-audit FP measurement, persistent per-intent reviewer calibration, multi-turn context, downloadable full-SHA-256 receipts logged to an append-only JSONL file, and explicit zero-LLM telemetry. Pure Python, fully deterministic, zero external dependencies beyond Streamlit and PyYAML.

Phase 2 - Enterprise pilot (target: one domain, one geography, 8-12 weeks).

- Real connectors to two or three systems-of-record (core lending, policy repo, CRM) behind the existing resolver interface.
- Shadow mode: gate runs beside production without enforcing; decisions and receipts are compared against live outcomes and reviewer judgement.
- Calibration: measure router precision/recall and gate FP/FN against reviewer overrides; tune per-profile strictness thresholds from evidence, not intuition; publish a calibration report for risk sign-off.
- Versioned YAML fact-contract registry in place, authored and iterated by the client's policy team.

Phase 3 - Scale (months 4-12).

- Per-domain contract libraries (retail lending -> cards, insurance, wealth) with template inheritance so new intents inherit and specialise rather than start from scratch.
- Drift monitoring: track router distribution shifts, verifier disagreement rates, override-rate trends, and source-freshness SLA breaches; alert policy owners when recalibration is due.
- Embeddings-assisted detection on the roadmap (per brief's detection menu): semantic similarity against known-bad phrasing corpora and near-duplicate claim clustering to extend coverage beyond rule-expressible patterns, still feeding the same typed-verifier economics (cheap detectors first).
- Multi-region deployment with jurisdiction overlay packs maintained as governed configuration.

SECTION 07

7. Key Risks & Mitigations

Risk	Why it matters	Mitigation
Over-flagging -> alert fatigue, user bypass	The brief flags bypass risk explicitly; a gate users route around is worse than none	Strictness is per-profile config, not global; batch-audit panel measures false-alarm rate on safe traffic as strictness rises; reviewer overrides feed back to relax thresholds adaptively (+/-0.02 per override); EDIT preferred over BLOCK where correction suffices
Contract authorship burden	Someone must define fact contracts per intent, or nothing gates	Versioned YAML registry with templates and per-domain libraries; Phase-2 pilot seeds initial contracts jointly with the client policy team; contracts are checklists of facts/sources/SLAs - deliberately simple enough for non-engineers
Router gaps (misrouted high-risk queries)	An unrecognized high-stakes ask could take the fast path	Fail-safe default: unknown intents fall to a conservative generic path that abstains when no verified KB entry exists - bias toward abstention, never invention; router precision/recall calibrated in shadow mode before enforcement switches on
Regulatory drift	Rules differ by geography and evolve; hard-coded rules age quickly	Jurisdiction overlays are governed configuration (law citations, retention, minimisation), not code; receipts record the overlay in force per decision, making historical rulings reproducible under the rules of their day
LLM cost creep	AI-as-judge everywhere would erode the unit economics	The prototype makes no external model calls and reports calls, tokens, and cost as zero. Any future judge adapter must expose measured tokens, cost, latency, confidence, and a deterministic fallback before enforcement

SECTION 08

8. Rubric Mapping - Round-2 Brief to Prototype

Round-2 brief bullet	Where the prototype addresses it
Detection techniques (heuristics, retrieval/source verification, PII/entity detection)	Regex/heuristic Risk Router (risk_router.py); deterministic source verification; local offer similarity scoring; PII vault matching with masked preview
Decision logic - tiered responses, confidence scoring, human pull-in rules	Seven-tier Decision Gate with per-claim confidence, severity, and deterministic precedence ladder (decision_gate.py)
Architecture - pipeline position, parallelism to protect latency	Inline input/output middleware; pre-generation routing so only gated traffic pays cost; parallel verifier execution implemented in the prototype
Governance - configurable policy layer, audit trail	Use-case profiles + jurisdiction overlays as config; SHA-256-sealed Evidence Receipt per decision, append-only log
Feedback loops	Review outcomes persist a separate threshold offset per intent; events are logged to feedback.jsonl
Metrics & monitoring - FP/FN, trustworthiness for skeptics	Batch audit: risky-case recall, false-alarm %, abstentions, p50/p95 latency, similarity checks, LLM calls, tokens, and estimated cost
One-size-fits-all doesn't work; different latency/risk budgets	Profiles: chatbot 800 ms / internal 2 s / decision-desk 5 s with distinct strictness
Multi-turn & agent compounding risk	Action intents forced to HUMAN_CONFIRM (dual control); compounding-risk rationale recorded in routing reasons and receipts
API-consumed models limit inspection	Enforcement entirely at input/output layer - no model internals required